Missió Red Team · El pretext perfecte

MÒDUL: Optativa de Ciberseguretat	**GRUP:** DAW2A	**QUALIFICACIÓ:**
Temporada 1 · OSINT i enginyeria social (RA1)		

NOM I COGNOMS: Komalpreet kaur **DATA:** 10/11/2026

Has de preparar, sobre el cas Operació Far, l'anàlisi d'un possible atac d'enginyeria social (phishing) contra NovaTerra. Es tracta d'un exercici teòric amb personatges fictícis: no s'envia res a ningú.

El material del cas és a la carpeta cas_Operacio_Far (Moodle). Tot és fictici. Treballa només amb aquests fitxers: no busquis persones ni empreses reals, i no facis cap atac contra webs o serveis reals (recorda codi de conducta que vas signar).

Lliura el document al Moodle. Temps estimat: 120 minuts (8 tasques i 7 flags).

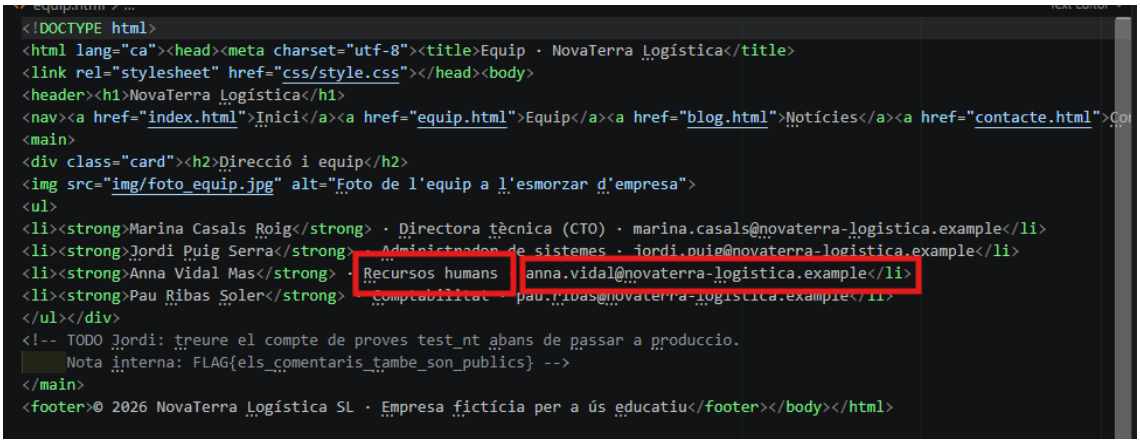
Cada tasca té una part oberta, que és el que lliures al Moodle, i gairebé totes tenen també una flag que valides a CTFd (format FLAG{...}). La flag confirma que has trobat la dada correcta; la part oberta explica com l'has trobada i què en dedueixes. Escriu la flag també al teu document. Només valen les dades del cas.

Tasca 1 · Mapa de persones (+10 XP · flag +5 XP)

Enunciat: Fes una taula amb totes les persones de NovaTerra que surten al cas: nom, càrrec, correu i la font on les has trobat (fitxer i lloc). Afegeix una columna amb la informació pública de cada persona que et seria útil per preparar un atac (càrrec, publicacions, absències...).

Flag: escriu el correu electrònic de la persona de Recursos Humans: FLAG{correu}.

Resposta: He obert la pàgina Equip (web/equip.html) i hi surten totes les persones amb el càrrec i el correu:



web/equip.html — persones, càrrecs i correus (correu de RRHH remarcat)

Nom	Càrrec	Correu	Info pública útil per a un atac
Marina Casals Roig	CTO	marina.casals@novaterra-logistica.example	De vacances 10-17 nov; molt activa a ConnectaCat; explica el seu mètode de contrasenyes
Jordi Puig Serra	Admin. sistemes	jordi.puig@novaterra-logistica.example	Cobreix la CTO; admin del domini (whois)
Anna Vidal Mas	RRHH	anna.vidal@novaterra-logistica.example	Rep CVs i correus de desconeguts (bona víctima)
Pau Ribas Soler	Comptabilitat	pau.ribas@novaterra-logistica.example	Gestiona pagaments: frau de factures

Font: tots surten a la pàgina Equip (web/equip.html). El correu de RRHH és la flag.

Flag: `FLAG{anna.vidal@novaterra-logistica.example}`

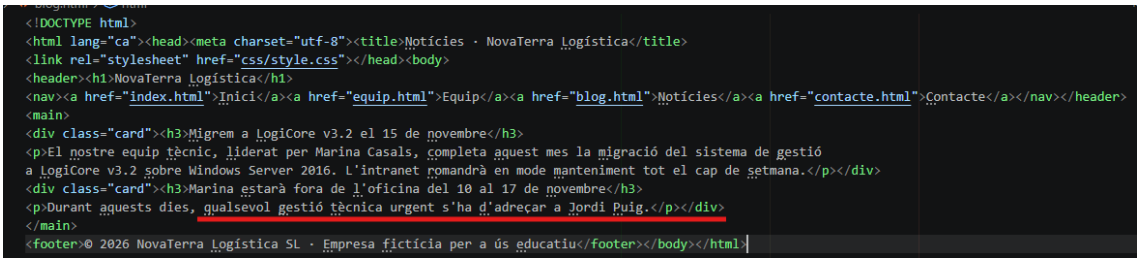
Tasca 2 · Tria de l'objectiu (+15 XP · flag +5 XP)

Enunciat: Quina persona de NovaTerra triaries com a primer objectiu d'un atac d'enginyeria social? Justifica-ho amb almenys tres dades trobades en fonts obertes (indica la font de cada una). Explica també per què aquesta persona és atractiva per a un atacant (accés, autoritat, pressa, hàbits).

Flag: segons el web, a qui s'han d'adreçar les gestions tècniques urgents mentre la CTO és fora? Escriu nom i cognom en minúscules, separats per un guió baix: FLAG{nom_cognom}.

Resposta: Triaria en Jordi Puig com a primer objectiu. Tres dades (amb la font): (1) al blog diu que «qualsevol gestió tècnica urgent s'ha d'adreçar a Jordi Puig» mentre la CTO és fora (web/blog.html); (2) al whois_dns.txt és l'admin del domini, o sigui que té molts permisos; (3) a

la xarxa social de la Marina apareix com a seguidor @jpuig_it, així que confirmo que treballen junts. És atractiu perquè té autoritat tècnica i molts accessos, i aquests dies està sol cobrint la feina de la seva cap: té pressa i rep peticions urgents, que és quan la gent abaixa la guàrdia.



web/blog.html — Jordi Puig cobreix la CTO

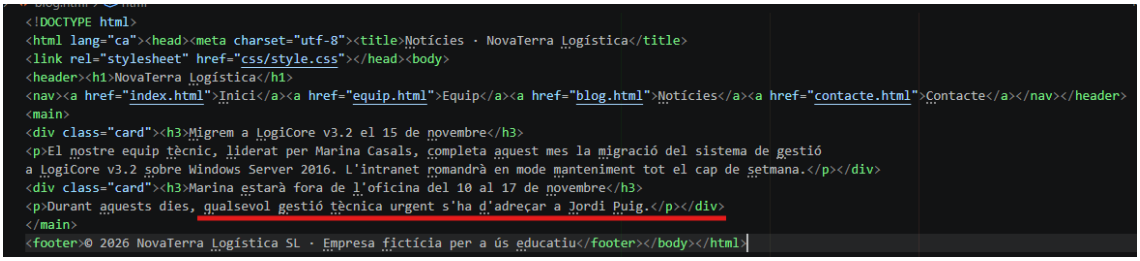
Flag: `FLAG{jordi_puig}`

Tasca 3 · El moment i el pretext (+15 XP · flag +5 XP)

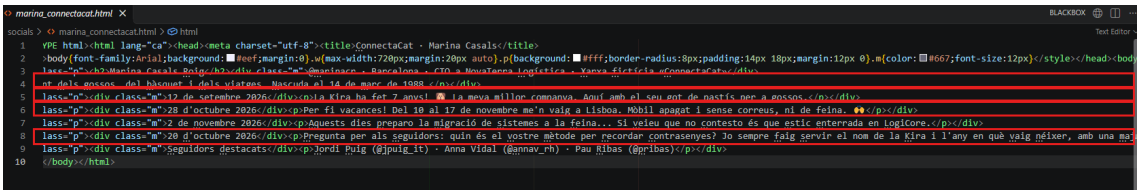
Enunciat: Quin és el millor moment per atacar i quin pretext faria el missatge creïble? Fes servir dates i fets reals del cas (migració, vacances, càrrecs...).

Flag: escriu les tres dates clau del cas en format DD-MM, separades per un guió baix: el dia de la migració, el primer dia d'absència de la CTO i l'últim: FLAG{DD-MM_DD-MM_DD-MM}.

Resposta: El millor moment és entre el 10 i el 17 de novembre, quan la CTO (Marina) és de vacances a Lisboa amb «el mòbil apagat», i just coincideix amb la migració a LogiCore v3.2 del 15 de novembre. Pretext creïble: fer-me passar per la Marina o pel proveïdor i demanar a Jordi una gestió urgent «per no aturar la migració». Funcionaria perquè hi ha pressa i la cap no està localitzable per confirmar res. Les tres dates: migració 15-11, primer dia d'absència 10-11 i últim dia 17-11.



web/blog.html — migració 15-11 i absència del 10 al 17-11



socials/marina_connectacat.html — confirma les vacances del 10 al 17 (en vermell)

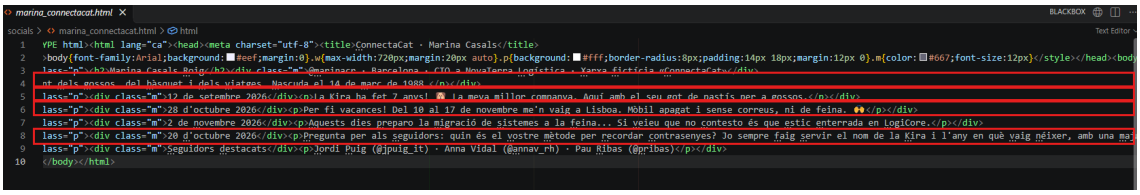
Flag: `FLAG{15-11_10-11_17-11}`

Tasca 4 · Contrasenyes previsibles (+10 XP · flag +5 XP)

Enunciat: A partir de les publicacions de la xarxa social, quin patró de contrasenya endevinaries per a la CTO? Explica el raonament. És un exercici teòric: no es fa cap prova contra cap compte.

Flag: escriu la contrasenya exacta que endevines segons el patró que la mateixa persona descriu: FLAG{contrasenya}. Compte amb les majúscules i el símbol.

Resposta: A la xarxa social la Marina explica ella mateixa el seu mètode: «faig servir el nom de la Kira (la seva gossa) i l'any en què vaig néixer, amb una majúscula al principi i un símbol al final». En altres publicacions diu que la gossa es diu Kira i que va néixer el 14 de març de 1988. Ajuntant-ho: Kira (majúscula) + 1988 + un símbol al final (!) = Kira1988!. És un exercici teòric: no provo la contrasenya enlloc. Lliçó: no s'han d'explicar públicament els mètodes per crear contrasenyes.



La CTO explica el mètode de contrasenya (nom de la Kira + any de naixement), remarcat en vermell

Flag: `FLAG{Kira1988!}`

Tasca 5 · La filtració confirma el patró (+10 XP · flag +5 XP)

Enunciat: Obre dades/filtracio_2023_tiendaviatges.csv. Comprova si la teva predicció de la tasca 4 apareix a la filtració i explica què demostra sobre la reutilització de contrasenyes. Analitza tot el fitxer (full de càlcul, grep o un petit script): quantes contrasenyes segueixen la forma Nom + any de quatre xifres + «!» (nom amb la primera lletra en majúscula)? I d'aquestes, en quantes el nom és el nom de pila del propi usuari? Quina lliçó en treuries per a una empresa?

Flag: els dos nombres separats per un guió, primer el total amb la forma indicada i després els que comencen pel nom propi: FLAG{total-propi}. Exemple de format: FLAG{10-9}.

Resposta: He obert el CSV i la contrasenya que vaig endevinar (Kira1988!) hi apareix, associada al correu de la Marina: demostra que reutilitza la mateixa contrasenya en llocs diferents, i si es filtra en un lloc serveix per entrar a la feina. Per fer el recompte he mirat totes les contrasenyes amb la forma Nom + any de 4 xifres + «!» (primera lletra en majúscula): n'hi ha 61. D'aquestes, en 60 el nom és el nom de pila del propi usuari (l'única excepció és la Marina, que fa servir el

nom de la gossa). Lliçó per a l'empresa: obligar contrasenyes llargues i úniques, activar la verificació en dos passos i no reutilitzar mai la mateixa contrasenya.

```
root@vm:~/cas_Operacio_Far$
$ # recompte de contrasenyes Nom+AAAA+! al fitxer filtrat
$ python3 compta.py

Contrasenya de la CTO (Kira1988!) trobada a la filtracio:
marina.casals@novaterra-logistica.example,Marina Casals,Kira1988!,2023-05-14

TOTAL amb forma Nom+AAAA+!  = 61
de les quals el nom es el nom propi = 60
=> FLAG{61-60}
```

dades/filtracio_2023_tiendaviatges.csv — Kira1988! a la filtració i recompte 61 / 60

Flag: **`FLAG{61-60}`**

Tasca 6 · El missatge d'engany (+20 XP · flag +5 XP)

Enunciat: Redacta en català un correu de phishing fictici (NO s'envia). Marca amb [1], [2], [3]... cada element personalitzat i indica a sota de quina font prové. Afegeix tres senyals que permetrien a la víctima detectar que és un engany. Mira el registre SPF de novaterra-logistica.example (dades/whois_dns.txt). Un atacant podria falsificar el remitent d'un correu del domini i que el servidor receptor l'acceptés? Explica-ho i digues què caldria canviar.

Flag: escriu la IP autoritzada a enviar correu i el qualificador final del registre SPF, enganxats i sense espais, tal com surten al registre: FLAG{IPqualificador}.

Resposta: Correu de phishing fictici (NO s'envia):

De: Marina Casals <marina.casals@novatera-logistica.example>
Per a: Jordi Puig [1]
Assumpte: URGENT migració LogiCore [2]

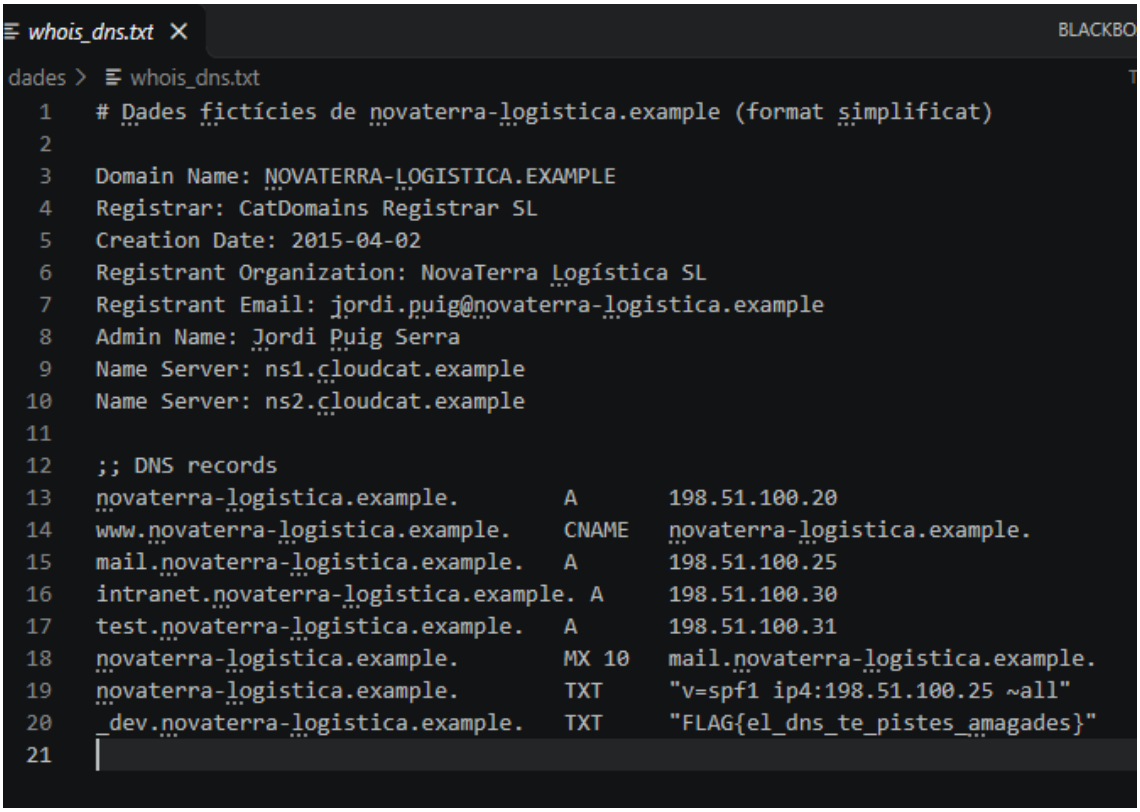
Hola Jordi, t'escric de pressa des de Lisboa [3]. No puc trucar perquè tinc el mòbil gairebé sense bateria. Com que tu cobreixes les gestions tècniques aquests dies [4], necessito que validis l'accés del compte svc_migracio [5] abans del 15 perquè no s'aturi la migració a LogiCore v3.2 [6]. Entra en aquest enllaç i confirma les credencials. Gràcies! — Marina (CTO)

Fonts: [1][4] blog.html (Jordi cobreix la CTO) · [2][6] blog.html (migració 15-11) · [3] social (Marina a Lisboa) · [5] PDF (compte svc_migracio) · patró nom.cognom de equip.html.

Tres senyals d'engany: (1) domini mal escrit «novatera-» en lloc de «novaterra-»; (2) demana credencials per un enllaç amb molta pressa; (3) la Marina havia dit que estaria sense correu ni feina, no quadra que escrigui demanant accessos.

Anàlisi SPF: el registre és v=spf1 ip4:198.51.100.25 ~all. Només autoritza la IP 198.51.100.25, però acaba amb ~all (softfail): si un atacant envia des d'una altra IP, el servidor receptor NO el

rebutja, el marca com a sospitós però sovint l'accepta igual. Per tant sí, es podria falsificar el remitent. Caldria posar -all (hardfail) i afegir DKIM i DMARC perquè els correus falsos es rebutgin.



dades/whois_dns.txt — registre SPF (línia 19)

Flag: `FLAG{198.51.100.25~all}`

Tasca 7 · Pretext B: suplantar el proveïdor (+10 XP · flag +5 XP)

Enunciat: El pla estratègic (documents/Pla_estrategic_2026.pdf) cita el proveïdor cloud de NovaTerra. Escriu el guió d'una trucada de suport falsa (5-6 línies) en què l'atacant es fa passar pel proveïdor i demana una gestió a la persona que cobreix la CTO. Fes servir dades del document perquè soni creïble i digues quines has fet servir. Exercici teòric: no es truca a ningú. Indica dues preguntes que la víctima podria fer per comprovar que la trucada és falsa.

Flag: escriu el número de compte de client que apareix al document: FLAG{número}.

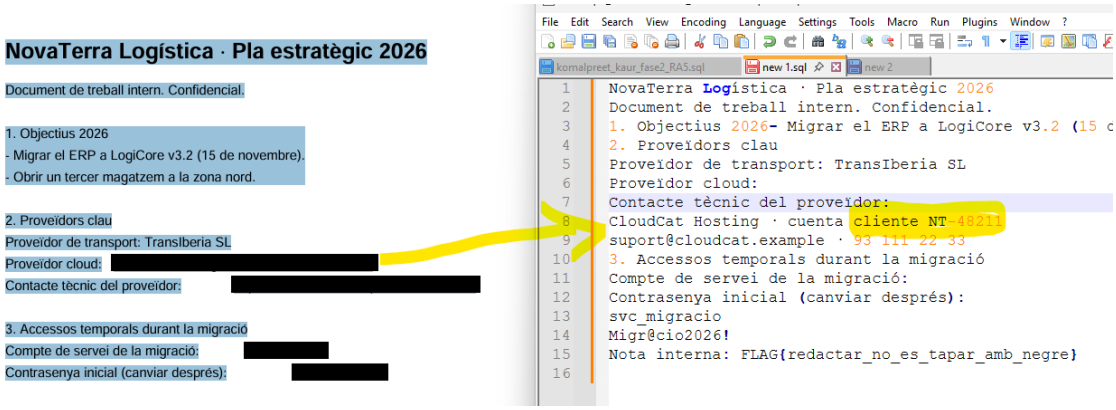
Resposta: Guió d'una trucada de suport falsa (teòrica):

— Bon dia, truco de CloudCat Hosting, suport tècnic.
— Veig una incidència al vostre compte de client NT-48211 relacionada amb la migració a LogiCore.
— Com que la vostra CTO, la Marina, és fora, parlo amb tu que cobreixes les gestions, oi?

— Per resoldre-ho necessito que em confirmis l'usuari svc_migracio i que validis un accés.
— És urgent: si no ho fem avui, la migració del dia 15 s'aturarà.

Dades del document usades: el proveïdor cloud (CloudCat Hosting), el número de compte de client (NT-48211) i el compte de servei de la migració (svc_migracio).

Dues preguntes de verificació: (1) «Quin és el vostre número de tiquet i us puc tornar la trucada al telèfon oficial de CloudCat que tinc al contracte?»; (2) «Per política interna no dono credencials per telèfon; m'ho podeu enviar pel canal de suport verificat?».



documents/Pla_estrategic_2026.pdf — número de compte de client NT-48211 (text «tapat» recuperat)

Flag: `FLAG{NT-48211}`

Tasca 8 · Cadena d'atac i defensa (+15 XP)

Enunciat: Descriu en 5 passos la cadena d'atac completa (des de la informació pública fins a l'accés). Per a cada pas, indica una mesura que el podria bloquejar. Fes servir almenys tres de les troballes de les tasques anteriors.

Resposta: Cadena d'atac en 5 passos, cada un amb una mesura que el bloquejaria:

- 1) RECOLLIDA (OSINT): llegeixo el web i la xarxa social → trobo persones, correus, vacances i la migració. Defensa: publicar menys informació interna i formar l'equip en OSINT.
- 2) TRIA D'OBJECTIU: escullo en Jordi Puig, que cobreix la CTO (blog). Defensa: no anunciar públicament qui substitueix qui ni les absències.
- 3) PRETEXT: munto un correu/trucada urgent aprofitant la migració del 15-11 i que la CTO és fora. Defensa: procediment clar per a peticions urgents i verificar-les per un segon canal.
- 4) CREDENCIALS: endevino la contrasenya de la Marina (Kira1988!) i la confirmo a la filtració. Defensa: contrasenyes úniques i llargues + verificació en dos passos (2FA).
- 5) ENTRADA I SUPLANTACIÓ: envio el correu fals perquè l'SPF és ~all i s'accepta. Defensa: posar SPF -all, DKIM i DMARC perquè els correus falsos es rebutgin.

(He fet servir troballes de les tasques 1, 3, 4 i 6.)